



Administrator and Production Support Manual

TASCO Insurance × VETC Growth Platform — User Manuals

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

Part A — User administration (administrator)

Part B — Operations (administrator and support engineer)

Troubleshooting (quick reference)

Document	Version	Date	Owner	Status
Administrator and Production Support Manual	1.0	07 October 2026	iorta TechNXT — Business Analysis and DevSecOps	Issued for submission

Platform administrator		Support engineer
Role	admin	support_engineer
Demo user	admin (MFA required)	support
Permissions	users:manage, ops:read, ops:run_jobs, audit:read, rules:read, dashboard:read	ops:read, ops:run_jobs
Landing page	Home	Operations

Separation of duties: administrators manage accounts and operations but **cannot author or approve rules and cannot see customer personal data**. Support engineers can see operational status and run jobs only. They cannot see customers, dashboards or rules. Do not request extra roles to "make support easier". Escalate instead.

Read the [Staff User Manual](#) first. Technical runbooks (RB-01 ... RB-15) and standard operating procedures (SOP-01 ... SOP-09) are in the Runbook and Support Guide (docs/operations/runbook-and-support-guide.pdf). This manual covers day-to-day use of the Users and Operations pages.

Part A — User administration (administrator)

A1. Roles reference

Role	Give to	MFA	Key capabilities
admin	Platform administrators (2–3 people)	Required	Users, operations, audit read
executive	Leadership	Recommended	Dashboards
campaign_manager	Marketing / growth		Leads, journeys, voice campaigns, rules read
telesales_agent	Agents (set region)		Handoffs, customers with PII, quote and send to the customer
telesales_supervisor	Team leads		Agent rights + assign handoffs + dashboards
rule_author	Product analysts		Draft and simulate rules
rule_approver	Compliance, underwriting approvers	Required	Approve or reject rules, audit read
compliance_officer	Compliance / DPO office	Required	Approve rules (including restricted kinds), audit, DSAR
data_steward	Data team	Required	DQ, corrections, ingestion, PII
claims_handler	Claims team		FNOL queue
partner_manager	Partnerships		Partners, API keys, statements
auditor	Internal audit	Recommended	Read-only audit, rules, dashboards
support_engineer	Production support		Operations status and jobs

Roles requiring MFA are set by configuration (`MFA_REQUIRED_ROLES` , default `admin,rule_approver,compliance_officer,data_steward`). A user with such a role **enrols their own authenticator app at first sign-in** by scanning a QR code that only they see. Administrators never see authenticator keys.

Least privilege and separation of duties: choose only the roles the person needs. The platform refuses forbidden role combinations ("Separation of duties: X and Y cannot be held by the same person"). The forbidden pairs, defined in `config/security/rbac.json` , are:

Role	Cannot be combined with
admin	rule_author, rule_approver, compliance_officer, data_steward, telesales_agent, telesales_supervisor, campaign_manager, partner_manager
rule_author	rule_approver, compliance_officer

The platform also blocks self-approval of rules, but the separation should be organisational too.

A2. Create a user

Prerequisites: approved access request (manager + data owner for PII roles), training certification for the role (see the Change Management and Training Plan), and the user's region.

1. Open **Users**. The **Create user** form is next to the user list.
2. Enter:
 - **Username:** lowercase letters, digits, `.`, `_`, `-` (for example `nguyen.van.an`);
 - **Display name;**
 - **Temporary password (≥ 12 chars):** at least 12 characters (maximum 128), following the password policy;
 - **Region:** for agents and supervisors the exact region name used in customer data (for example `Hà Nội` , `TP. Hồ Chí Minh`), otherwise `ALL` ;
 - **Roles:** select the required roles ("Least privilege — choose only what the person needs");
 - **Enrol MFA (mandatory for privileged roles):** ticked by default. MFA is always required for the roles in the MFA list, whatever this box says.
3. Select **Create**.

What you will see: "Created `<username>` ." No authenticator key is shown: the user enrolls it at first sign-in.

4. Give the user the temporary password through a secure channel (for example in person).
5. At first sign-in the user must set their own password (the **Please set your own password** dialog cannot be skipped). Users with an MFA role then scan the enrolment QR code.

The action is audited (`user.created` , with roles and region).

Production with corporate single sign-on (OIDC to TASCO's IdP): accounts and MFA are managed in the IdP, and this page is used only for role and region mapping. This is planned for scale-out.

A3. Change roles, region or status

- **Disable / Enable:** in the **Users** list, select **Disable** (or **Enable**) on the user's row.
- **Roles and region:** in v1 these are changed through the API, `PATCH /api/users/:id` with `roles` and/or `region` . The console form for this is planned.

What you will see: the updated row. Any change of roles, region or status takes effect at once: the user's existing sessions stop working and they must sign in again. Audited as `user.updated`.

You **cannot change your own roles or status** ("You cannot change your own roles or status"). Another administrator must do it.

A4. Leavers and movers

- **Leaver: Disable** on or before the last day. Do not delete accounts, because the audit trail needs them.
- **Mover:** change roles and region on the effective date. Remove roles that are no longer needed.
- **Quarterly access review:** export the user list (roles, region, MFA, last login, status) for Security and Compliance. Disable accounts with no login for 90 days unless justified.

A5. Locked accounts, lost MFA devices and forgotten passwords

Administrators can unlock an account and force MFA re-enrolment with `POST /api/users/:id/reset` (body `{"unlock": true}`, `{"resetMfa": true}` or both). The action is audited as `user.reset`. You cannot reset your own account ("Ask another administrator to reset your own account").

Situation	Procedure
Locked after 5 failed attempts (password or code)	The lock clears automatically after 15 minutes (<code>LOCKOUT_MINUTES</code>). For urgent cases, verify the user's identity and unlock (<code>unlock: true</code>). Repeated lockouts may indicate an attack: check <code>auth.login_failed</code> and <code>auth.mfa_failed</code> in Audit first.
Lost or new phone (MFA)	Verify the user's identity, then reset MFA (<code>resetMfa: true</code>). Existing sessions end, and the user scans a new QR code at the next sign-in.
Forgotten password	v1 has no administrator password reset. Disable the account at once if compromise is suspected. Then follow SOP-08 in the Runbook and Support Guide (<code>docs/operations/runbook-and-support-guide.pdf</code>), or create a replacement account (for example <code>nguyen.van.an2</code>) with the same roles and record the link in the ticket. Under IdP federation this is handled in the IdP.

A6. Demo accounts (training and UAT only)

Demo users (`admin`, `exec`, `campaign`, `agent.hn`, `agent.hcm`, `supervisor`, `author`, `approver`, `compliance`, `steward`, `claims`, `partners`, `auditor`, `support`) exist **only** when the platform is seeded in demo mode. The seed job refuses to run unless `DEMO_MODE` is on.

- **Local demo:** the default demo password is `Tasco@Demo2026!`.
- **Hosted UAT:** a separate password is distributed in the access workbook. Never write it in documents, tickets or chat. UAT can also publish demo authenticator keys (`DEMO_TOTP_SEED`) and reset demo accounts at start-up (`DEMO_ACCOUNT_SYNC`).
- The demo MFA helper behind **Sign in with demo code (UAT)** (`GET /api/demo/totp/:username`) returns 404 when demo mode is off.

Production must **never** run with `DEMO_MODE` (the server refuses to start in production with demo mode unless explicitly overridden).

Part B — Operations (administrator and support engineer)

B1. Operations page

Open **Operations**. The page heading shows the **store** (`postgres` in production, `memory` only in local development) and the number of **audit entries**. **What you will see:**

Section	Meaning	Healthy state
Integrations: name and circuit	Circuit breaker state for each external system: <code>vetc-wallet</code> , <code>tasco-core</code> , <code>voice-ai</code> , <code>app-push</code> , <code>zalo-zns</code> , <code>sms</code>	closed (shown as active). open (shown as failed) means calls are failing fast. half_open means it is testing recovery.
Event backlog	Domain events by status (outbox)	Pending count near zero and not growing
Active rules	Each rule kind with its active version and checksum	All expected kinds present. Checksums match the change log.
Job history	Recent job runs: started, kind, actor, status, result	Scheduled jobs succeeded

B2. Run a job manually

1. In **Operations**, select the job button:

Button	What it does	When to run manually
Run reconciliation	Checks every order: completed orders must have a payment reference and every policy must exist; flags orders stuck in <code>pending_payment</code> for more than 1 hour, <code>compensation_failed</code> orders (manual action) and <code>payment_failed</code> orders (confirm with the VETC wallet that nothing was captured)	After a payment or issuance incident, or when Finance queries
Run retention	Applies the <code>retention</code> rule set (deletes raw source records after 365 days and voice sessions after 180 days; other entities are flagged for the archival pipeline)	Only if the scheduled run failed
Run relay	Processes pending domain events (outbox)	When the event backlog grows

2. **What you will see:** a message with the result. For reconciliation, the number checked, the number of mismatches and up to 100 details (order ID and issue). The run appears in **Job history** and is audited (`job.<kind>`).

Equivalent command-line jobs (scheduled in production): `npm run job -- <name>`, where the name is `journeys`, `recompute`, `reconcile`, `retention`, `relay`, `rules`, `migrate`, `seed` (demo mode only) or `openapi`.

B3. Health and monitoring endpoints

Endpoint	Use
GET <code>/health/live</code>	Liveness: the process is up (<code>{"status": "ok"}</code>)
GET <code>/health/ready</code>	Readiness: the database is reachable (200 <code>ready</code> / 503 <code>not_ready</code> , with <code>db: true/false</code>). Load balancers use this.
GET <code>/metrics</code>	Prometheus metrics (for example <code>http_requests_total</code> , <code>orders_completed_total</code> , <code>orders_compensation_total</code>). Protected by a bearer token when <code>METRICS_TOKEN</code> is set.
GET <code>/api/meta</code>	Version, demo mode flag, current date, store type

Endpoint	Use
GET /api/ops/status	Operations page data (needs ops:read)
GET /api/audit/verify	Audit chain integrity (needs audit:read: admin, not support)

Logs are structured JSON. Every request has a **request ID** (X-Request-Id header and requestId field). Users see its first characters as the "(ref ...)" support code on errors. Search logs by it.

B4. Incident triage guide

Symptom	Check	Action
Users cannot sign in (everyone)	/health/ready, database, JWT_SECRET unchanged	Restore the database connection. If the secret was rotated, all sessions end, which is expected.
Customers' payments fail	Operations → vetc-wallet circuit open . Order statuses payment_failed.	Contact VETC wallet on-call. Run reconciliation after recovery.
Orders paid but no certificate	tasco-core circuit. Orders issuance_failed_refunded or compensation_failed.	Issued lines are cancelled and the payment refunded automatically. Run reconciliation: compensation_failed orders need manual action (RB-11). Confirm with Finance. Contact TASCO core.
Reminders not sent	zalo-zns, sms, app-push circuits. Journey run summary. Messages failed.	Contact the provider. Re-run journeys after recovery (campaign manager).
Voice calls failing	voice-ai circuit	Contact the vendor. Campaigns pause by themselves.
Event backlog growing	Operations → event backlog	Run Relay . If it persists, check logs for subscriber errors.
Audit chain verification broken	Audit → Verify	Security incident: do not modify data. Escalate to Security and Compliance. Preserve logs.
Rule change "not taking effect"	Active rules checksum	Wait 15 seconds (cache). Check that it was approved, not just submitted. Ask for lead recompute.
"Too many requests" for many users	Rate limits (RATE_LIMIT_MAX, default 300 per minute per IP; sign-in 10 per minute)	Behind a proxy, check TRUST_PROXY and TRUST_PROXY_HOPS (the client IP is the right-most trusted hop of X-Forwarded-For). Otherwise many users may share one IP. Raise the limit by configuration change (CAB).

Severity and response (proposed): P1 (sales or sign-in down for all) respond 15 min, restore 4 h. P2 (one channel or integration down) 30 min / 8 h. P3 (single user or function) 4 h / 3 business days.

B5. Configuration and secrets (reference)

Set through environment variables. Secrets can be supplied as files with <NAME>_FILE.

Setting	Purpose
NODE_ENV=production	Enables strict checks: secrets and DATABASE_URL required, demo mode refused. Hosted UAT uses NODE_ENV=uat.
DATABASE_URL, DATABASE_SSL, DB_POOL_MAX	PostgreSQL. Production refuses to start without DATABASE_URL.

Setting	Purpose
JWT_SECRET, JWT_TTL_SECONDS (default 1800)	Staff and customer tokens
DATA_KEYS, DATA_KEY_ACTIVE	Field encryption keys for rotation (comma-separated id:key pairs)
BLIND_INDEX_KEY	Searchable encrypted fields
MFA_REQUIRED_ROLES	Roles that must use MFA
LOCKOUT_MAX_FAILURES (5), LOCKOUT_MINUTES (15)	Account lockout (password and code)
RATE_LIMIT_WINDOW_MS, RATE_LIMIT_MAX, RATE_LIMIT_LOGIN_MAX	Rate limiting
CORS_ORIGINS, TRUST_PROXY, TRUST_PROXY_HOPS, PUBLIC_BASE_URL	Web and network
METRICS_TOKEN	Bearer token protecting /metrics
LINK_TTL_DAYS (30)	Lifetime of signed customer renewal links
DEMO_MODE, SEED_RECORDS, SEED, SIM_TODAY	Demo environments only (DEMO_MODE is off by default)
DEMO_PASSWORD, DEMO_TOTP_SEED, DEMO_ACCOUNT_SYNC	Hosted UAT only: demo password override, published demo authenticator keys, demo account reset at start-up

Changes to RBAC (`config/security/rbac.json`) and security settings go through code review and the **Change Advisory Board**. They are never edited on a running server.

Troubleshooting (quick reference)

Message	Meaning	Fix
"Unknown role X"	Typo in the role name	Use a role from the A1 table
"Separation of duties: X and Y cannot be held by the same person"	Forbidden role combination	Choose one of the two roles (see A1)
"You cannot change your own roles or status"	Self-administration is blocked	Ask another administrator
"Password policy" with details	Temporary password does not meet the policy	Use 12–128 characters that meet the policy shown
"Username already exists"	Duplicate	Choose another username
"Job kind not found"	Wrong job name (API)	Use reconciliation, retention or relay
"Missing permission ops:run_jobs"	Read-only operations role	Ask an administrator or support engineer

See also: Runbook and Support Guide ([docs/operations/runbook-and-support-guide.pdf](#)), Knowledge Transfer Plan ([docs/delivery/kt-plan.pdf](#)), [Staff User Manual](#).